Offre de Services : Accompagnement Cybersécurité des Développeurs

devSec & perspectives

Présenté par : L'équipe SECD

Date : 28 avril 2026

Le défi : Concilier vélocité de développement et exigences de sécurité

La banque durcit ses contrôles avec l'arrivée imminente des **Security Gates** obligatoires dans les pipelines CI/CD. Sans un support structuré, le risque est de bloquer la production et de créer une rupture entre les équipes Cyber et les Développeurs.

LES POINTS DE FRICTION IDENTIFIÉS

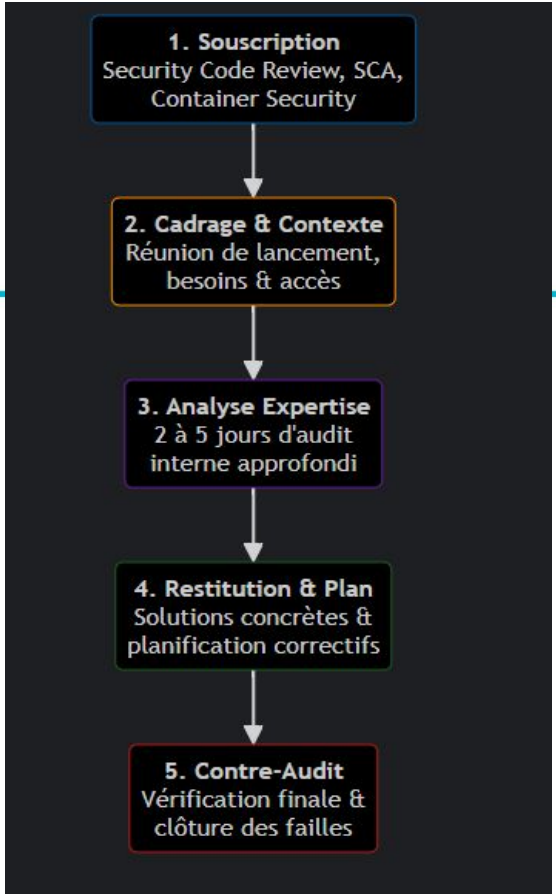
- Des pipelines qui s'arrêtent sans explication claire pour le développeur.
- Des rapports de vulnérabilités (SCA/SAST) perçus comme trop complexes.
- Un besoin de remédiation post-pentest qui reste souvent en attente faute d'expertise dédiée côté dev.

Notre réponse

Une offre de services à laquelle les équipes doivent souscrire pour bénéficier d'un accompagnement personnalisé et lever les blocages.

Gouvernance & Cycle de Remédiation : L'Offre de Services en Action

Le cycle de remédiation end-to-end



Notre mission : Faire de chaque développeur un acteur de la sécurité

VISION DE L'OFFRE

Proposer un accompagnement personnalisé, opérationnel et pédagogique aux équipes de développement afin qu'elles puissent livrer des applications sécurisées, sans être bloquées dans leurs pipelines et en comprenant les enjeux de chaque vulnérabilité.

✕ Ce que nous ne sommes PAS

Nous ne sommes pas une équipe de contrôle ou de sanction.

✓ Ce que nous SOMMES

Un **centre d'expertise cyber** au service des développeurs, avec une posture de conseil, de formation et d'accompagnement technique.

L'écosystème outillé : 4 piliers technologiques au service de la sécurité

OUTIL / MÉTHODE	PÉRIMÈTRE	RÔLE DANS L'OFFRE
JFrog Artifactory + Xray	**SCA — Analyse des dépendances**	Détection des CVE dans les librairies open source et les images Docker
SonarQube	**SAST — Analyse statique du code**	Identification des failles de sécurité dans le code source (injections, mauvaises pratiques)
Pentest (Interne/Externe)	**Test d'intrusion applicatif**	Validation de la sécurité par l'équipe Sécurité Offensive ou des cabinets externes
Audit Manuel	**Revue d'architecture & Code**	Accompagnement sur-mesure basé sur des checklists de sécurité spécifiques

Ces piliers couvrent l'ensemble du cycle de vie applicatif : du code source jusqu'au déploiement en production.

Le levier d'adoption : La Security Gate comme déclencheur

LE MÉCANISME DE SOUSCRIPTION

01 Le pipeline CI/CD scanne le code et les dépendances automatiquement.

02 Si un seuil critique est atteint, la **Security Gate bloque le déploiement** .

03 Le développeur est invité à **souscrire à l'offre** pour résoudre le blocage.

Ce que l'offre apporte au développeur

- Analyse approfondie du blocage
- Qualification des faux positifs
- Plan de remédiation priorisé

Modalités de souscription : Comment bénéficier de l'accompagnement ?

1. Souscription sur blocage (Réactif)

Accompagnement d'urgence pour lever une **Security Gate** bloquante en production ou pré-production.

2. Souscription post-pentest (Suivi)

Aide à la compréhension et à la remédiation suite à un rapport de l'équipe **Offensive** ou d'un prestataire externe.

3. Souscription proactive (Audit)

Demande d'**audit manuel** (Architecture/Code) avant le lancement d'un nouveau projet ou d'une release majeure.

Zoom SAST : SonarQube comme filet de sécurité dans le code

CE QUE SONARQUBE DÉTECTE

- Injections SQL, XSS, SSRF, XXE
- Mauvaise gestion des secrets (hardcoded credentials)
- Failles cryptographiques (algorithmes faibles, mauvaise gestion des certificats)
- Problèmes de contrôle d'accès

CE QUE L'OFFRE APPORTE

- Revue des findings avec le développeur
- Explication pédagogique de la vulnérabilité
- Qualification des faux positifs (avec justification documentée)
- Recommandations de correction avec exemples de code

LE WORKFLOW DANS LE PIPELINE CI/CD

1. À **chaque exécution** du pipeline (Job CI), SonarQube analyse le code source.
2. Les résultats sont catégorisés : **Blocker, Critical, Major, Minor** .
3. La **Quality Gate de sécurité** bloque si des issues Blocker/Critical sont présentes.
4. Le développeur accède au rapport pour localiser la faille exacte et comprendre le correctif nécessaire.

Audit Manuel : Checklists Code & Architecture Applicative

CHECKLIST ARCHITECTURE

Contrôle d'Accès (BOLA/IDOR) & Pre-authorization

un utilisateur ne doit pas pouvoir accéder aux données d'un tiers en modifiant un ID dans l'URL (prévention des Insecure Direct Object Reference).

Gestion des Secrets

Absence de secrets en clair, utilisation systématique du **Vault bancaire** .

Authentification/Authorisation

Implémentation OIDC/OAuth2, gestion fine des habilitations (RBAC/ABAC/ReBAC).

Protection contre l'Exposition Excessive de Données

Data Transformation : Utilisation de la Gateway pour masquer ou filtrer certains champs sensibles dans les réponses sortantes.
Minimisation : Ne renvoyer que le strict nécessaire au consommateur (éviter les objets JSON "full" de la base).

CHECKLIST REVUE DE CODE

Entrées/Sorties

Validation systématique, encodage (prévention XSS, SQL Injection).

Gestion des Erreurs

Pas d'infos sensibles dans les logs ou les messages d'erreur API.

Cryptographie

Utilisation de librairies standards et d'algorithmes robustes (AES-256).

Gestion des faux positifs : un enjeu critique pour la crédibilité de l'offre

LE PROBLÈME DES FAUX POSITIFS

Les outils SAST, SCA ou les Pentests génèrent parfois des faux positifs. Un doute non levé crée de la frustration et érode la confiance dans nos contrôles.

PRINCIPE DIRECTEUR

Toute exception est documentée, justifiée et réévaluée.
Aucun contournement silencieux.

Notre processus de qualification

ÉTAPE	ACTION	ACTEUR
1. Signalement	Le développeur conteste un finding (SCA, SAST ou Pentest)	Développeur
2. Analyse	Revue technique du contexte et de l'exploitabilité	Expert Cyber
3. Décision	Confirmation FP ou vrai positif avec justification	Expert Cyber
4. Documentation	Enregistrement de l'exception avec justification métier	Expert Cyber + Dev
5. Suivi	Réévaluation périodique des exceptions accordées	Expert Cyber

Roadmap : Calendrier de déploiement de l'offre

HORIZON	JALON CLÉ
T2 2026	Ouverture de la souscription pour les projets pilotes.
T3 2026	Généralisation de l'offre en lien avec l'activation globale des Security Gates.
T3 2026	Lancement du catalogue de formations et de la base de connaissances self-service.
T4 2026	Mise en place des tableaux de bord de suivi de la dette sécurité par équipe.

L'objectif est d'atteindre une couverture complète des projets critiques d'ici **fin 2026** .

Conclusion : L'accompagnement, levier de la culture DevSecOps

CE QUE CETTE OFFRE CHANGE CONCRÈTEMENT

- Les développeurs ne sont plus seuls face aux exigences de sécurité.
- Les Security Gates et les Pentests deviennent des **opportunités d'amélioration** .
- La sécurité s'intègre naturellement dans le cycle de développement.

NOTRE ENGAGEMENT

> *Chaque développeur qui passe par notre offre repart avec une meilleure compréhension de la sécurité applicative et les moyens concrets de livrer du code sûr.*

Prochain jalon

Présentation du tableau de bord de suivi et lancement du catalogue de formations — **T3 2026** .

QUESTIONS & ÉCHANGES